

CVEs más relevantes de la semana

Del 16/05/2026 al 23/05/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2020-37228

Descripción: iDS6 DSSPro Digital Signage System 6.2 contains a CAPTCHA security bypass vulnerability that allows attackers to bypass authentication by requesting the autoLoginVerifyCode object. Attackers can retrieve valid CAPTCHA codes via the login endpoint and use them to perform brute-force attacks against user accounts.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-307

Tecnología: No especificado

Publicado el: 2020-05-16



CVE-2020-37239

Descripción: libbabl 0.1.62 contains a broken double free detection vulnerability that allows attackers to bypass memory safety checks by exploiting signature overwriting in freed chunks. Attackers can call `babl_free()` twice on the same pointer without triggering detection, as libc's malloc metadata overwrites babl's signature field upon freeing, enabling potential memory corruption and code execution.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-415

Tecnología: No especificado

Publicado el: 2026-05-16



CVE-2021-47952

Descripción: python jsonpickle 2.0.0 contains a remote code execution vulnerability that allows attackers to execute arbitrary Python commands by deserializing malicious JSON payloads containing py/repr objects. Attackers can craft JSON strings with py/repr directives that invoke the eval function during deserialization to execute system commands and arbitrary code.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-05-16



CVE-2026-8751

Descripción: A security flaw has been discovered in h2oai h2o-3 up to 7402. This affects the function importBinaryModel of the file h2o-core/src/main/java/hex/Model.java of the component JAR Handler. Performing a manipulation results in deserialization. The attack is possible to be carried out remotely. The exploit has been released to the public and may be used for attacks. The vendor was contacted early a...

CVSS: 7.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-05-17



CVE-2018-25320

Descripción: ACL Analytics versions 11.x through 13.0.0.579 contain an arbitrary code execution vulnerability that allows attackers to execute arbitrary commands by leveraging the EXECUTE function. Attackers can use bitsadmin to download malicious PowerShell scripts and execute them with system privileges to establish reverse shells and gain complete system control.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-05-17



CVE-2018-25332

Descripción: GitBucket 4.23.1 contains an unauthenticated remote code execution vulnerability that allows attackers to execute arbitrary commands by exploiting weak secret token generation and insecure file upload functionality. Attackers can brute-force the Blowfish encryption key, upload a malicious JAR plugin via the git-lfs endpoint, and execute system commands through an exposed exploit endpoint.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-05-17



CVE-2018-25335

Descripción: WordPress Plugin Peugeot Music 1.0 contains an arbitrary file upload vulnerability that allows unauthenticated attackers to upload malicious files by sending POST requests to the upload.php endpoint. Attackers can upload files with arbitrary extensions by manipulating the 'name' parameter to execute code from the uploads directory.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-05-17



CVE-2026-8757

Descripción: A vulnerability was found in adenhq hive up to 0.11.0. This affects the function `_read_events_tail` of the file `core/framework/server/routes_sessions.py` of the component Delete Request Handler. Performing a manipulation results in path traversal. The attack may be initiated remotely. The exploit has been made public and could be used. The vendor was contacted early about this disclosure but did ...

CVSS: 7.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-05-17



CVE-2026-41947

Descripción: Dify version 1.14.1 and prior contains an authorization bypass vulnerability that allows authenticated editor users to set and enable trace configurations for any application regardless of tenant ownership. Attackers can exploit missing tenant ownership checks in the trace configuration endpoints to redirect all messages and responses from victim applications to attacker-controlled LLM trace pr...

CVSS: 7.4 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-639

Tecnología: No especificado

Publicado el: 2026-05-18



CVE-2026-41948

Descripción: Dify version 1.14.1 and prior contain a path traversal vulnerability that allows authenticated users to manipulate requests forwarded to the Plugin Daemon's internal REST API by exploiting insufficient URL path sanitization. Attackers can traverse out of their authorized tenant path using unencoded dot sequences in task identifiers or manipulated filename parameters to access internal endpoints...

CVSS: 7.7 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:L

Tipo: CWE-23

Tecnología: No especificado

Publicado el: 2026-05-18



CVE-2026-45230

Descripción: DumbAssets through 1.0.11 contains a path traversal vulnerability in the POST /api/delete-file endpoint and filesToDelete array parameters that allows unauthenticated attackers to delete arbitrary files by supplying ../ sequences that bypass directory boundary validation. Attackers can exploit the optional and disabled-by-default authentication control to traverse outside the intended applicati...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-05-18



CVE-2026-45495

Descripción: Microsoft Edge (Chromium-based) Remote Code Execution Vulnerability

CVSS: 8.8 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-05-18



CVE-2026-4885

Descripción: The Piotnet Addons for Elementor Pro plugin for WordPress is vulnerable to arbitrary file upload due to missing file type validation in the 'pafe_ajax_form_builder' function in all versions up to, and including, 7.1.70. The plugin uses an incomplete extension blacklist that only blocks php, phpt, php5, php7, and exe extensions, while allowing dangerous extensions such as .phar or .phtml to be u...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-05-19



CVE-2026-4883

Descripción: The Piotnet Forms plugin for WordPress is vulnerable to arbitrary file upload due to missing file type validation in the 'piotnetforms_ajax_form_builder' function in all versions up to, and including, 2.1.40. The plugin uses an incomplete extension blacklist that only blocks php, phpt, php5, php7, and exe extensions, while allowing dangerous extensions such as .phar or .phtml to be uploaded. Th...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-05-19



CVE-2026-43633

Descripción: HestiaCP versions 1.9.0 through 1.9.4 contain a deserialization vulnerability in the web terminal component caused by a session format mismatch between PHP and Node.js that allows unauthenticated remote attackers to achieve root-level code execution. Attackers can inject crafted data into HTTP headers that are processed by the PHP session handler but incorrectly deserialized by the Node.js web ...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-05-19



CVE-2026-8602

Descripción: In ScadaBR version 1.2.0, a Missing Authentication for Critical Function vulnerability could allow an unauthenticated attacker to send a HTTP GET requests to the SCADA system and inject arbitrary sensor readings.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-05-19



CVE-2026-8603

Descripción: In ScadaBR version 1.2.0, an OS Command Injection vulnerability could allow an attacker to execute commands as root on the SCADA system.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-05-19



CVE-2026-8605

Descripción: In ScadaBR version 1.2.0, a Use of Hard-Coded Credentials vulnerability could allow an attacker to access the SCADA system as admin.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-798

Tecnología: No especificado

Publicado el: 2026-05-19



CVE-2026-33642

Descripción: Kitty is a cross-platform GPU based terminal. In versions 0.46.2 and below, the `handle_compose_command()` function in `kitty/graphics.c` performs bounds validation on composition offsets using unsigned 32-bit arithmetic that is subject to integer wrapping, potentially leading to Heap Buffer Over-Read/Write. An attacker who can write escape sequences to a kitty terminal (e.g., via a malicious file,...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:L/I:L/A:H

Tipo: CWE-125

Tecnología: No especificado

Publicado el: 2026-05-19



CVE-2026-6555

Descripción: The ProSolution WP Client plugin for WordPress is vulnerable to Arbitrary File Upload in versions up to, and including, 2.0.0. This is due to an array validation mismatch where only the first file in the upload array undergoes extension and MIME type validation, while all files are processed and uploaded to a web-accessible directory. This makes it possible for unauthenticated attackers to uplo...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-05-20



CVE-2026-7284

Descripción: The Easy Elements for Elementor – Addons & Website Templates plugin for WordPress is vulnerable to privilege escalation via user registration in all versions up to, and including, 1.4.4. This is due to the 'easyel_handle_register' function not restricting what user roles a user can register with. This makes it possible for unauthenticated attackers to supply the 'administrator' role during regi...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-269

Tecnología: No especificado

Publicado el: 2026-05-20



CVE-2025-33255

Descripción: NVIDIA TRT-LLM for any platform contains a vulnerability in MPI server, where an attacker could cause an unsafe deserialization. A successful exploit of this vulnerability might lead to code execution, denial of service, data tampering, and information disclosure.

CVSS: 7.5 (HIGH)

Vector: CVSS:3.1/AV:L/AC:H/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-05-20



CVE-2026-24142

Descripción: NVIDIA TRT-LLM for any platform contains a deserialization vulnerability and unsafe serialized handle. A successful exploit of this vulnerability might lead to code execution, data tampering, and information disclosure.

CVSS: 6.3 (MEDIUM)

Vector: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:C/C:L/I:L/A:L

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-05-20



CVE-2026-24163

Descripción: NVIDIA TRT-LLM for any platform contains a vulnerability in RPC testing, where an attacker could cause an unsafe deserialization. A successful exploit of this vulnerability might lead to code execution, denial of service, data tampering, and information disclosure.

CVSS: 7.5 (HIGH)

Vector: CVSS:3.1/AV:L/AC:H/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-05-20



CVE-2026-24206

Descripción: NVIDIA Triton Inference Server contains a vulnerability where an attacker could cause an authentication bypass. A successful exploit of this vulnerability might lead to escalation of privileges, denial of service, or information disclosure.

CVSS: 7.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-288

Tecnología: No especificado

Publicado el: 2026-05-20



CVE-2026-24213

Descripción: NVIDIA Triton Inference Server contains a vulnerability in the DALI backend where an attacker could cause an out-of-bounds read. A successful exploit of this vulnerability might lead to code execution, data tampering, denial of service, or information disclosure.

CVSS: 8.0 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:H/I:H/A:H

Tipo: CWE-125

Tecnología: No especificado

Publicado el: 2026-05-20



CVE-2026-24214

Descripción: NVIDIA Triton Inference Server contains a vulnerability in the DALI backend where an attacker could cause an integer overflow. A successful exploit of this vulnerability might lead to code execution, data tampering, or denial of service.

CVSS: 8.0 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:H/I:H/A:H

Tipo: CWE-190

Tecnología: No especificado

Publicado el: 2026-05-20



CVE-2026-7637

Descripción: The Boost plugin for WordPress is vulnerable to PHP Object Injection in versions up to, and including, 2.0.3 via deserialization of untrusted input in the STYXKEY-BOOST_USER_LOCATION cookie. This makes it possible for unauthenticated attackers to inject a PHP Object. No known POP chain is present in the vulnerable software, which means this vulnerability has no impact unless another plugin or t...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-05-20



CVE-2026-33278

Descripción: NLnet Labs Unbound 1.19.1 up to and including version 1.25.0 has a vulnerability in the DNSSEC validator that enables denial of service and possible remote code execution as a result of deep copying a data structure and erroneously overwriting a destination pointer. An adversary can exploit the vulnerability by controlling a malicious signed zone and querying a vulnerable Unbound. When DS sub-q...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-416

Tecnología: No especificado

Publicado el: 2026-05-20



CVE-2026-42960

Descripción: NLnet Labs Unbound up to and including version 1.25.0 is vulnerable to poisoning via promiscuous records for the authority section. Promiscuous RRSets that complement DNS replies in the authority section can be used to trick Unbound to cache such records. If an adversary is able to attach such records in a reply (i.e., spoofed packet, fragmentation attack) he would be able to poison Unbound's c...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:N/I:H/A:H

Tipo: CWE-349

Tecnología: No especificado

Publicado el: 2026-05-20



CVE-2025-31973

Descripción: HCL BigFix Service Management (SM) is susceptible to a Configuration – 'Insecure Use of Base Image Version'. Using outdated or insecure base images may introduce known vulnerabilities, potentially increasing the risk of exploitation in the application environment.

CVSS: 4.0 (MEDIUM)

Vector: CVSS:3.1/AV:L/AC:L/PR:H/UI:R/S:U/C:L/I:L/A:L

Tipo: NVD-CWE-noinfo

Tecnología: No especificado

Publicado el: 2026-05-20



CVE-2026-3593

Descripción: A use-after-free vulnerability exists within the DNS-over-HTTPS implementation. This issue affects BIND 9 versions 9.20.0 through 9.20.22, 9.21.0 through 9.21.21, and 9.20.9-S1 through 9.20.22-S1. BIND 9 versions 9.18.0 through 9.18.48 and 9.18.11-S1 through 9.18.48-S1 are NOT affected.

CVSS: 7.4 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:H

Tipo: CWE-416

Tecnología: No especificado

Publicado el: 2026-05-20



CVE-2026-20223

Descripción: A vulnerability in the access validation of internal REST APIs of Cisco Secure Workload could allow an unauthenticated, remote attacker to access site resources with the privileges of the Site Admin role. This vulnerability is due to insufficient validation and authentication when accessing REST API endpoints. An attacker could exploit this vulnerability if they are able to send a ...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-05-20



CVE-2026-9139

Descripción: Taiko AG1000-01A SMS Alert Gateway Rev 7.3 and Rev 8 contains a hard-coded credential vulnerability in the embedded web configuration interface where authentication is implemented entirely in client-side JavaScript in login.zh.html, exposing static plaintext credentials in the page source. Unauthenticated attackers with network access can recover administrative credentials directly from the client...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-798

Tecnología: No especificado

Publicado el: 2026-05-20



CVE-2026-8631

Descripción: A potential security vulnerability has been identified in the HP Linux Imaging and Printing Software. This potential vulnerability may allow escalation of privileges and/or arbitrary code execution via an integer overflow in the hpcups processing path when handling crafted print data.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-122

Tecnología: No especificado

Publicado el: 2026-05-20



CVE-2026-6279

Descripción: The Avada Builder (fusion-builder) plugin for WordPress is vulnerable to Unauthenticated Remote Code Execution via PHP Function Injection in versions up to and including 3.15.2. This is due to the `wp\_conditional\_tags` case in `Fusion\_Builder\_Conditional\_Render\_Helper::get\_value()` passing attacker-controlled values from a base64-decoded JSON blob directly to `call\_user\_func()` without any allo...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-05-21



CVE-2026-4858

Descripción: Mattermost versions 11.6.x <= 11.6.0, 11.5.x <= 11.5.3, 11.4.x <= 11.4.4, 10.11.x <= 10.11.14 fail to check integration URL for path traversal which allows an malicious authenticated user to call an arbitrary API via system admin Mattermost auth token using via path traversal in integration action URL.. Mattermost Advisory ID: MMSA-2026-00640

CVSS: 8.0 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-05-21



CVE-2026-5118

Descripción: The Divi Form Builder plugin for WordPress is vulnerable to privilege escalation in versions up to, and including, 5.1.2. This is due to the plugin accepting a user-controlled 'role' parameter from POST data during user registration without validating it against the form's configured default_user_role setting. This makes it possible for unauthenticated attackers to create administrator accounts...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-269

Tecnología: No especificado

Publicado el: 2026-05-21



CVE-2026-6960

Descripción: The BookingPress Pro plugin for WordPress is vulnerable to arbitrary file uploads due to missing file type validation in the 'bookingpress_validate_submitted_booking_form_func' function in all versions up to, and including, 5.6. This makes it possible for unauthenticated attackers to upload arbitrary files on the affected site's server which may make remote code execution possible. Note: The vu...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-05-21



Resumen del Reporte

CVEs analizados: 39

Promedio CVSS: 8.89

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat 🐱

